

HW06-AI API Testing Report - EShop

Field	Value
Student	NGUYEN THIEN NHA TRAN
Student ID	23127272
Class	23KTPM2
Date	18/08/2026
SUT commit	85af3ba875c88283615e22cb108f13e2fccaf0e9
Local execution URL	http://127.0.0.1:3001

1. Scope and selection

The API choices are inherited from the student's final HW02/HW04 artifacts.

Pool	Feature	Tested endpoints
A	FR-03 Forgot password/password reset	POST /api/forgot-password; POST /api/reset-password
B	FR-11 Order history/cancellation	GET /api/orders/my-orders; supporting GET /api/orders/:id; PUT /api/orders/:id/cancel
C	FR-14 Category CRUD	GET/POST /api/categories; PUT/DELETE /api/categories/:id

The student must still confirm that no group member has the same three-feature combination.

2. Method and audit workflow

The reusable skill follows this pipeline: inspect requirements and API specification; enumerate request/response variables; derive valid and invalid equivalence classes; add boundary values; model state and ownership transitions; trace SEC-01 through SEC-07; define exact JSON schemas; generate at least 35 AI cases; audit them; add five student-origin extensions; build Postman v2.1; execute with Newman; and triage only reproducible contract deviations as bugs.

The reviewed catalog is test-design/test-cases.json. The untouched generation snapshot is test-design/test-cases-ai-original.json. Their comparison is under AI docs/evidence/setup-session/ai-final-comparisons/test-catalog.md. All 120 reviewed cases include an audit verdict and rationale. A-STU-038 remains INCOMPLETE/manual because OTP expiry needs a controllable clock or authorized wait fixture; immediately exercising it would produce invalid evidence.

3. Pool A - FR-03

Inputs include email presence/type/format, registration state, OTP presence/type/length/value/lifecycle, and password length/complexity. Boundaries cover missing/null/empty values, seven/eight-character passwords, OTP shape, token rotation, injection strings, and malformed JSON. Response checks enforce JSON content type, allowed status, required properties, and no unexpected fields.

Designed: 40 cases (35 AI + 5 student-origin). Executed: 39. Passed: 18. Failed: 21. Not run: 1.

Main findings:

- BUG-01: forgot-password returns a four-digit OTP instead of six digits.
- BUG-02: reset-password accepts weak, empty, null, and missing passwords.
- BUG-03: malformed email inputs are treated as unknown accounts instead of being validated.
- BUG-04: malformed JSON produces an HTML error page rather than the API error schema.

The five extensions emphasize OTP lower boundary, token rotation, expiry, password whitespace, and response secrecy. The first AI pass focused mainly on single-request partitions and therefore underrepresented lifecycle and cross-request checks.

4. Pool B - FR-11

The suite covers no/invalid/valid authentication, empty and populated histories, ownership isolation, order detail, order states (pending, confirmed, shipping, delivered, canceled), cancellation rules, ID boundaries, SQL-like identifiers, schema consistency, and data integrity. Each stateful case creates an isolated user/order through explicit sequential setup requests.

Designed/executed: 40. Passed: 34. Failed: 6.

Main findings:

- BUG-05: GET /api/orders/:id is public and exposes non-owned orders (IDOR).
- BUG-06: a shipping order can be canceled, and the forbidden transition persists.
- BUG-07: a negative total created through supporting checkout is returned as a valid-looking history item.

The student-origin extensions add persistence after a rejected transition, direct public-IDOR access, HTML-safe addresses, negative-total integrity, and status-count consistency. These require multi-request state reasoning rather than a single endpoint oracle.

5. Pool C - FR-14

The CRUD matrix covers public reads, admin/user/no/malformed authentication, name type and boundaries, duplicate and injection-like values, malformed JSON, existing/nonexistent/zero/negative/nonnumeric IDs, update isolation, repeated delete, and exact list/message/error schemas.

Designed/executed: 40. Passed: 19. Failed: 21.

Main findings:

- BUG-08: normal users can perform category mutations (role escalation).
- BUG-09: create/update accepts invalid category names.
- BUG-10: update/delete reports success for nonexistent or invalid IDs.
- BUG-04: malformed JSON returns HTML rather than JSON.

The five extensions cover trimming, role escalation, HTML-as-data, update isolation, and repeated-delete behavior. The first AI pass needed explicit prompting for mutation repetition and persistence effects.

6. Security traceability

Requirement	Representative tests	Result
SEC-01 Sensitive-data protection	A-AI-012, A-STU-040, B-AI-014, B-AI-015	Covered; selected responses did not expose password/SQL internals
SEC-02 Authentication/ownership	B-AI-001-B-AI-035, C-AI-002, C-AI-020, C-AI-030	Failed for public/non-owner order detail
SEC-03 Role authorization	C-AI-008, C-AI-021, C-AI-032, C-STU-037	Failed; normal users mutate categories
SEC-04 XSS-safe handling	A-AI-011, B-STU-038, C-STU-038	Covered as JSON data
SEC-05 Injection resistance	A-AI-010, B-AI-024, C-AI-016, C-AI-027, C-AI-028	Queries remained parameterized; invalid IDs still return wrong success status
SEC-06 Profile update authorization	None	Explicitly deferred: selected APIs do not update profiles
SEC-07 Reset-token security	A-AI-001, A-AI-013-A-AI-034, A-STU-036-A-STU-040	Failed OTP length/password validation; expiry not runtime-tested

7. Postman/Newman design and features used

Used and evidenced locally: Collection v2.1, folders, collection variables, a local environment, collection-level pre-request script, X-Student-Id header injection, sequential state setup requests, bearer tokens, dynamic IDs, JSON bodies, raw malformed bodies, request test scripts, JSON Schema assertions, custom cross-request checks, CLI/JSON/HTML Newman reporters, and environment overrides.

Not claimed without student evidence: Postman workspace sharing, console screenshot, Collection Runner data file, monitor, or mock server. The student may add these only after real use.

The first generated harness used asynchronous setup inside pre-request scripts. Newman did not wait for those Promises, causing false 401 results. The corrected builder emits setup as ordinary sequential Collection requests and writes runtime values to both collection and environment scopes. A final clean run recorded zero setup/script failures.

8. Execution summary

Metric	Pool A	Pool B	Pool C	Total
Designed	40	40	40	120
AI-generated	35	35	35	105
Student-origin extensions	5	5	5	15
Executed	39	40	40	119
Passed	18	34	19	71
Failed	21	6	21	48
Not run	1	0	0	1

Newman executed 348 sequential setup/test request items and 601 assertions. Failed assertions: 86. Setup, pre-request, and test-script failures: 0. The command exited 1 because real contract assertions failed. Evidence: `reports/newman-cli.txt`, `reports/newman-report.json`, and `reports/newman-report.html`.

9. Bug reporting

Ten reproducible bug groups are documented with representative request/status/body evidence in `bug-reports.md`. Public GitHub Issue URLs and screenshots are deliberately blank because publishing and screenshot capture require student action. The report must not claim those requirements complete until the real issue pages exist.

10. CI/CD

`.github/workflows/hw06-api.yml` installs the pinned Newman toolchain, validates the generator/catalog, checks out the pinned SUT, starts it, runs the collection, and uploads reports on success or failure. The workflow is prepared but no GitHub run is claimed. The student must push and capture the required passing and deliberate-failure run links/screenshots. Because the pinned SUT contains intentional bugs, a genuine all-contract-tests-passing run requires a corrected SUT; weakening expected results is not acceptable.

11. AI-driven test generator

The reusable skill is `skills/generate-eshop-api-tests/`. It includes a strict catalog validator, Postman collection builder, three unit tests, promptable workflow instructions, a catalog template, pseudocode, and a pipeline reference. Validation enforces per-API counts, AI/student origins, equivalence-class references, security traceability/dispositions, schema coverage, audit labels, and the student-ID header mechanism.

The required diagram remains student-owned. `test-generator/SELF-DRAWN-DIAGRAM-REQUIRED.md` is only a checklist; it is not submitted as the diagram.

12. Limitations and student checklist

- Confirm the three-feature combination is unique in the group.
- Review/sign all preliminary AI verdicts and the AI audit.
- Capture a real Postman Console screenshot showing X-Student-Id: 23127272.
- Publish the ten reviewed issue drafts and attach real screenshots.
- Push and record two real CI runs.
- Draw and export the generator diagram personally.
- Perform the OTP-expiry test with an authorized timing fixture.
- Add optional monitor/mock/data-run evidence only if actually used.

AI Critique

The AI was useful for expanding a small specification into systematic domain partitions, boundary cases, security traces, JSON schemas, and an executable Postman collection. However, its first output was incomplete in two important ways. First, it emphasized isolated request-response cases and did not naturally prioritize cross-request behavior. Tests for OTP rotation, persistence after a rejected shipping cancellation, update isolation, and repeated deletion were added only after comparing the generated suite with my HW02/HW04 evidence. These cases require remembering state across several calls, which a prompt organized mainly around parameters and status codes tends to underweight. Second, the AI-generated test harness itself was wrong. It placed asynchronous setup calls in a Newman pre-request script using top-level `await`; after a syntax fix, Newman still sent the main request before the Promise completed. This produced misleading 401 failures. The mistake was found by examining the full execution report rather than accepting a large failure count as proof of SUT defects. I corrected the design so registration, login, state transitions, and fixture creation run as ordinary sequential Collection requests, then reran from a clean seeded database. The final run had zero setup or script failures, so the remaining failures could be triaged against the contract. The AI also proposed some status expectations more confidently than the specification justified, so I kept the specification as the oracle and grouped related symptoms instead of reporting every failed assertion as a separate bug. My main lesson is that collaborating with AI requires two independent reviews: validate the test oracle, and validate the test mechanism. High coverage is not credible when prerequisites, timing, variable scope, or evidence provenance are wrong. AI accelerates enumeration and automation, but the student must control state, audit assumptions, reproduce findings, and refuse fabricated evidence.

AI Audit Report - HW06-AI

1. Student Information

Field	Value
Student name (printed):	NGUYEN THIEN NHA TRAN
Student ID:	23127272
Class / Cohort:	23KTPM2
Assignment ID:	HW06-AI - API Testing
Assignment date:	18/08/2026
AI tool(s) used:	OpenAI Codex; Context7 documentation connector
AI used in this assignment:	Yes

2. Instructions

The table records AI-assisted artifacts using VALID, INVALID, or INCOMPLETE. Verdicts below are evidence-based drafts; the student must review and sign them. Full prompt/output evidence is in evidence/setup-session/codex-chat-logs/codex-chat-log.md; raw technical logs are retained separately and are not copied into this table.

3. Audit Table

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning	(5) Student Fix
Tool: OpenAI Codex Time: 18/08/2026 Prompt: "Read D:\CODE\23127272_CS13003_HW\HW06-AI\2026.HW06.API Testing_En.md and set up skill and complete the hw06"	Reusable skill, validator, builder, report scaffolds, Postman environment, and CI workflow. Evidence: skills/generate-eshop-api-tests / and commit c860a0e.	INCOMPLETE	The initial output correctly created neutral infrastructure but could not select APIs without the student's decision. The assignment requires one choice from each pool and a complete per-API pipeline.	Student later instructed Codex to reuse HW02/HW04 selections.
Tool: OpenAI Codex Time: 18/08/2026 Prompt: "khoang chon trc api nhe"	Stopped at the API-selection gate and did not invent Pool A/B/C choices.	VALID	This obeyed the explicit constraint and preserved group-selection responsibility.	None.
Tool: OpenAI Codex Time: 18/08/2026 Prompt: "Còn api thì lấy theo nhx của chon của Hw02 và Hw04"	Selected FR-03, FR-11, and FR-14 from prior final artifacts; generated 120 cases, including 105 AI cases and 15 student-origin extensions; produced raw and reviewed catalogs.	INCOMPLETE	Coverage/counts/schema/security traceability validate, but all audit verdicts are still AI preliminary labels. One OTP-expiry case correctly remains manual/incomplete. Detailed comparison: evidence/setup-session/ai-final-comparisons/test-catalog.md.	Student reviews every verdict, confirms group uniqueness, and signs. Keep A-STU-038 incomplete until a valid timing fixture is used.
Tool: OpenAI Codex Time: 18/08/2026 Prompt: Same completion request; automate the selected cases in Postman/Newman.	Initial builder used asynchronous pre-request setup. The first retained run is under reports/harness-defect-run/.	INVALID	Top-level await was not accepted, and an async-IIFE workaround did not make Newman wait. This caused false authentication failures and could have misclassified harness defects as SUT bugs.	Replaced asynchronous setup with 229 explicit sequential setup requests, fixed variable-scope precedence, reset the SUT, and reran. Final setup/script failures: 0.

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning	(5) Student Fix
Tool: OpenAI Codex Time: 18/08/2026 Prompt: Same completion request; execute, analyze, and prepare submission artifacts.	Final local run: 119 executed cases, 71 passed, 48 failed, 1 not run; 10 reproducible bug groups; Markdown/CSV reports, Newman JSON/HTML, verified PDF exports, critique, and issue drafts.	INCOMPLETE	Local artifacts are evidence-backed, but XLSX authoring is blocked because the required artifact-tool dependency loader is unavailable. Anti-cheat and external-state requirements also require student work: screenshots, self-drawn diagram, published GitHub Issues, and CI run URLs.	Student exports/reviews the workbook in an artifact-tool-enabled session, captures/publishes required evidence, performs the manual expiry case, reviews PDFs, and updates links/signature.

4. AI Use Declaration

I use AI tools for assignment analysis, skill design, domain/security/schema test generation, catalog validation, Postman/Newman automation, result parsing, report drafting, spreadsheet/PDF preparation, and audit-log organization. I remain responsible for API uniqueness, test-oracle correctness, human verdicts, real execution screenshots, the self-drawn diagram, issue publication, CI evidence, and final submission accuracy.

5. Signature / Submission Checklist

Item	Status
Every AI-assisted artifact has a prompt/evidence reference	Complete for this Codex session
Every output has a draft verdict and reasoning	Complete
Invalid/incomplete outputs have fixes/actions	Complete
AI-original vs final catalog comparison attached	Complete
Codex transcript and raw JSONL attached	Complete
Student review/signature	STUDENT ACTION
Real screenshots, issue URLs, CI links, self-drawn diagram	STUDENT ACTION

Student confirmation: I reviewed all AI-generated material and remain responsible for the correctness of the submitted work.

Signature/date: **STUDENT ACTION**